

Security+ 2.5 · Segmentation & Access Control

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.5 — Segmentation & Access Control (6:06)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Isolamento network: VLAN / sub-rede / DMZ (screened subnet) — se um setor compromete, não contamina o resto. ACL (Access Control List) = o QUE pode entrar no recurso. Allowlist (default DENY — só o conhecido passa) > denylist (default ALLOW — bloqueio o conhecido). Microsegmentação = isolamento FINE-grained (o padrão de zero trust).

Highlights que a prova cobra

- DMZ: zona entre internet e rede interna — o público mora lá
- Allowlist (deny-by-default) é MAIS SEGURA que denylist
- Microsegmentação: cada carga isolada — Zero Trust aplicado

Dicas de prova & Cenários Típicos

- 'default deny, permit only known' = allowlist
- 'zone between internet and internal network' = DMZ/screened subnet

Cenário clássico de exame: Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas o interno não alcança' = DMZ/screened subnet.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.5 — Segmentation & Access Control)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.
Tente responder antes de olhar.

1. Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:

- A)** VLAN de voz
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. Usar VÁRIAS camadas de defesa (firewall + antivírus + MFA + treinamento) para não depender de uma só é:

- A)** Zero Trust
- B)** Defesa em profundidade
- C)** Fail-open
- D)** Segurança por obscuridade

3. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A) Escassez**
- B) Autoridade + urgência**
- C) Prova social**
- D) Reciprocidade**

4. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'DMZ: zona entre internet e rede interna — o público mora lá'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: DMZ: zona entre internet e rede interna — o público mora lá...**

5. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Allowlist (deny-by-default) é MAIS SEGURA que denylist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Implementar a solução correspondente: Allowlist (deny-by-default) é MAIS SEGURA que denylist...**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

6. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Microsegmentação: cada carga isolada — Zero Trust aplicado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Microsegmentação: cada carga isolada — Zero Trust aplicado...

7. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'default deny, permit only known' = allowlist'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'default deny, permit only known' = allowlist...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'zone between internet and internal network' = DMZ/screened subnet'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'zone between internet and internal network' = DMZ/screened subnet...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas o interno não alcança' = DMZ/screened subnet.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Segmentation & Access Control): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'DMZ: zona entre internet e rede interna — o público mora lá'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: DMZ: zona entre internet e rede interna — o público mora lá...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — DMZ (screened subnet).

✓ **Por que está certa:** A alternativa correta é 'DMZ (screened subnet)'. Uma DMZ (Zona Desmilitarizada), também chamada de sub-rede filtrada (screened subnet), é um segmento de rede isolado que fica entre a rede interna confiável e a rede externa não confiável (como a Internet). Ela hospeda servidores públicos, como web, e-mail, DNS e FTP, que precisam ser acessíveis externamente. O objetivo é que, se um desses servidores for comprometido, o atacante não tenha acesso direto à rede interna, pois há firewalls controlando o tráfego entre a DMZ e a rede interna. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.2), descreve a DMZ como uma zona de segurança para expor serviços públicos de forma controlada. A questão descreve exatamente essa função: sub-rede isolada que expõe servidores públicos protegendo a rede interna.

✗ **Por que as outras estão erradas:**

- *VLAN de voz*: VLAN de voz é uma rede local virtual dedicada a tráfego de VoIP (voz sobre IP), separando-o dos dados para garantir qualidade de serviço (QoS) e segurança. Ela não é projetada para expor servidores públicos à Internet; pelo contrário, isola o tráfego de voz. Não oferece o isolamento entre rede interna e externa que uma DMZ proporciona. Portanto, não atende ao requisito de proteger a rede interna enquanto expõe serviços públicos.
- *VPN*: VPN (Virtual Private Network) é uma tecnologia que cria um túnel criptografado para transmitir dados de forma segura através de redes não confiáveis, permitindo acesso remoto ou interconexão de filiais. Embora melhore a segurança da comunicação, não é uma sub-rede isolada para hospedar servidores públicos. Uma VPN pode ser usada para acessar a DMZ, mas não substitui a DMZ. A questão pede uma zona de rede que exponha servidores públicos, o que não é a função primária de uma VPN.
- *Intranet*: Intranet é uma rede privada interna que utiliza tecnologias da Internet (como HTTP, FTP) para compartilhar informações dentro de uma organização. Ela é acessível apenas por usuários autorizados e não é exposta ao público externo. Portanto, não serve para hospedar servidores públicos que precisam ser acessados pela Internet. A intranet é o oposto de uma DMZ nesse aspecto: é interna e restrita, não uma zona de exposição controlada.

2) B — Defesa em profundidade.

✓ **Por que está certa:** A alternativa correta é 'Defesa em profundidade'. Defesa em profundidade (defense in depth) é uma estratégia de segurança que emprega múltiplas camadas de controles de segurança, de modo que, se uma camada falhar, outras ainda protejam o sistema. Isso inclui controles físicos, técnicos e administrativos, como firewalls, antivírus, autenticação multifator (MFA), treinamento de usuários, políticas, criptografia, entre outros. O objetivo é não depender de uma única medida de segurança. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.1), descreve defesa em profundidade como um conceito central. A questão descreve exatamente isso: usar várias camadas de defesa para não depender de uma só.

✗ **Por que as outras estão erradas:**

- *Zero Trust*: Zero Trust é um modelo de segurança que assume que nenhuma entidade, dentro ou fora da rede, é confiável por padrão. Ele exige verificação contínua de identidade e contexto para cada acesso, seguindo o princípio de 'nunca confie, sempre verifique'. Embora Zero Trust possa incluir múltiplas camadas, seu foco principal é a verificação explícita e o menor privilégio, não simplesmente a ideia de camadas de defesa. A questão descreve a estratégia de múltiplas camadas, que é defesa em profundidade, não o modelo Zero Trust.
- *Fail-open*: Fail-open é um modo de falha em que, quando um sistema de segurança falha, ele

permite a passagem do tráfego ou acesso, em vez de bloqueá-lo. Isso é o oposto de uma postura segura, que geralmente prefere fail-secure (fail-closed). Fail-open não é uma estratégia de defesa em camadas; é um comportamento de falha que pode ser configurado em alguns dispositivos, mas não descreve a prática de usar múltiplas defesas.

- *Segurança por obscuridade*: Segurança por obscuridade é a prática de esconder detalhes de implementação ou informações como forma de proteção, por exemplo, usar portas não padrão ou nomes de arquivos secretos. É considerada uma prática fraca, pois não resiste a um atacante determinado que descobre a obscuridade. Não se refere a múltiplas camadas de defesa; pelo contrário, é uma única camada frágil. A questão descreve a combinação de várias defesas, o que é defesa em profundidade.

3) B — Autoridade + urgência.

✓ **Por que está certa:** A alternativa correta é 'Autoridade + urgência'. A engenharia social explora vieses cognitivos e princípios psicológicos para manipular vítimas. No cenário, o golpista se passa por suporte de TI, o que invoca o princípio da autoridade (a vítima tende a obedecer a figuras de autoridade). Além disso, ele cria um senso de urgência para pressionar a vítima a agir rapidamente, sem pensar criticamente. A combinação de autoridade e urgência é uma tática clássica de engenharia social, reconhecida pela CompTIA. Portanto, a opção 'Autoridade + urgência' descreve com precisão os princípios explorados.

✗ Por que as outras estão erradas:

- *Escassez*: Escassez é um princípio de persuasão que explora a percepção de que recursos são limitados, criando uma sensação de que a oportunidade pode ser perdida se não agir imediatamente. No cenário, não há menção a recursos escassos ou ofertas limitadas. O golpista não está oferecendo algo em quantidade limitada, mas sim se passando por autoridade e criando urgência. Portanto, escassez não é o princípio aplicável.
- *Prova social*: Prova social é a tendência de as pessoas seguirem o comportamento dos outros, assumindo que ações tomadas por muitos são corretas. No ataque descrito, não há menção a outras pessoas fazendo o mesmo ou endossando a ação. O golpista não usa a ideia de que 'todos estão fazendo' para convencer a vítima. Portanto, prova social não é o princípio explorado.
- *Reciprocidade*: Reciprocidade é o princípio de que as pessoas se sentem obrigadas a retribuir um favor ou concessão. No cenário, o golpista não oferece nada primeiro para depois pedir a senha; ele simplesmente se passa por suporte e cria urgência. Não há troca de favores. Portanto, reciprocidade não se aplica.

4) D — Implementar a solução correspondente: DMZ: zona entre internet e rede interna — o público mora lá....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): DMZ: zona entre internet e rede interna — o público mora lá.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: Allowlist (deny-by-default) é MAIS SEGURA que denylist....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): Allowlist (deny-by-default) é MAIS SEGURA que denylist.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Microsegmentação: cada carga isolada — Zero Trust aplicado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): Microsegmentação: cada carga isolada — Zero Trust aplicado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: 'default deny, permit only known' = allowlist....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): 'default deny, permit only known' = allowlist.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'zone between internet and internal network' = DMZ/screened subnet....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): 'zone between internet and internal network' = DMZ/screened subnet.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): Cenário: 'web server público mora numa sub-rede que pode falar com o DB mas o interno não alcança' = DMZ/screened subnet..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: DMZ: zona entre internet e rede interna — o público mora lá....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Segmentation & Access Control): DMZ: zona entre internet e rede interna — o público mora lá.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.